Flag 11 of 18: Raw Database Dump File

OAuth Heist scenario · Cymbal Investments · Google SecOps SIEM

Question

Once authenticated to that internal server, what is the file name of the raw database dump exported by the attacker prior to compressing it into an archive?

Answer

cymbal_cust_q3.bak

Evidence

Both events are on `CYM-DB-01.cymbal.corp`, user `svc_dbadmin`, parent process `wsmprovhost.exe` (WinRM):

- **Export, 20:50:11Z.** `sqlcmd.exe` ran `BACKUP DATABASE [CymbalWealthMaster] TO DISK='C:\ProgramData\MSSQL\Backup\cymbal_cust_q3.bak' WITH FORMAT, COMPRESSION=OFF`. The `TO DISK=` path names the raw dump, and `COMPRESSION=OFF` confirms it is uncompressed.
- **Compression, 21:13:41Z.** `zstd.exe -3 -T0 -o C:\ProgramData\cymbal_q3_exfil.tar.zst C:\ProgramData\MSSQL\Backup\cymbal_cust_q3.bak`. The input is the same `.bak` file, and the output is the archive that was later uploaded.

How it was found

File-creation searches returned nothing, because no file creation was logged for the dump and the command line sits in `target.process.command_line`, not `principal.process`. A host search on the database server listed the process launches:

```
principal.namespace = "Cymbal"
AND (principal.hostname = /DB/ nocase OR target.hostname = /DB/ nocase)
```

Opening the `sqlcmd.exe` and `zstd.exe` events showed the full command lines.

Lesson

On a process-launch event, the new process is under `target.process` and the parent is under `principal.process`. Read the command line, and confirm the dump name against the compression command input.

Next pivot

The archive `cymbal_q3_exfil.tar.zst` is the next artifact. Find where it was sent.